

AI 기반 오탐 검토

☉ Category	Security Analysis
≡ Description	오탐률을 낮추기 위해 AI로 실제 위협 취약점인지 검토
123 ID	Func-04
✧ Status	시작 전

Overview

- 목표 : 정적 분석 및 경로 분석 결과로 도출된 취약점 후보들을 재검토, 실제 공격이 불가능한 가짜 위험 제거 → 개발자가 불필요한 보안 수정에 시간을 낭비하지 않도록 정확한 정보 제공
- 대상 사용자 : 분석 결과 중 가장 시급하고 실제적인 위협부터 해결하고자 하는 개발자 및 보안 관리자

User Flow & Logic

1. 정적 분석과 AI 경로 분석을 통해 발견된 모든 취약점 데이터를 수집
2. 해당 코드가 실행되는 환경을 AI가 파악
3. 발견된 취약점이 실제 환경에서 방어 기제에 의해 차단되는지, 혹은 공격자가 접근 불가능한 내부 로직인지 AI가 판단
4. 분석 결과를 실제 위협과 오탐으로 분류, 오탐으로 판명된 항목은 근거 기록
5. 최종적으로 걸러진 취약점들만 사용자의 메인 대시보드와 리포트에 표시

Data Specification

Input

- 잠재적 취약점 목록 → list (앞선 단계에서 탐지된 모든 취약점)
- 보안 설정 파일 → 데이터 묶음 (프로젝트의 환경 설정 및 보안 필터링 정보)

Output

- 정제된 취약점 목록 → list (오탐 제거된 최종 취약점 목록)

- 오탐 판별 사유 → string (왜 오탐인 지에 대한 설명)

Exception Handling

- 판단 근거 부족 : AI가 오탐 여부를 결정하기에 데이터가 부족하면 미확정 상태로 두고 사용자 확인 요청
- 분석 시간 초과 : 대량의 데이터 검토 시 지연 발생 가능성, 지연 시 위험도가 높은 항목 부터 순차적으로 검토 결과 업데이트

Security Requirements

- 판정 로직 비공개 : 어떤 기준으로 오탐을 걸러내는지에 대한 세부 로직이 외부로 유출되어 공격자가 이를 우회하지 못하도록 보안 유지